

TaradomeMusik Security Architecture Threat Model (STRIDE)

Version 1.0 • Generated 2026-02-21

System Boundaries

Web (Next.js) → API (NestJS) → Data (PostgreSQL/Redis/Object Storage) + External Integrations (CRM, Payments, DSPs).

Assets to Protect

- Fan PII (email/phone/location/consent)
- Artist contracts/royalty splits (internal)
- Ledger and financial records (immutability)
- Payment and subscription state
- Media masters and pre-release assets
- Sponsorship contracts and deliverables evidence
- Admin credentials and API keys (CRM/Stripe/etc)

STRIDE Analysis by Component

Category	Example Threats	Controls / Mitigations
Spoofing	Account takeover; forged webhooks; token replay	MFA; OAuth2/JWT w/ short TTL; webhook signature verification; refresh token rotation
Tampering	API payload manipulation; media URL tampering; ledger tampering	Request validation; signed URLs; WAF rules; immutable ledger entries + redundancy
Repudiation	Disputes over payouts or sponsor deliverables; missing audit log	Idempotent requests; request IDs; tamper-evident logs; time-stamped state changes
Information Disclosure	PII leaks; pre-release audio leaks; secret leaks	Field-level encryption for PII; least privilege; secrets manager; log redaction
Denial of Service	Traffic floods; abusive preview streaming; API abuse	Rate limiting; bot detection; autoscaling; circuit breakers; queue-based processing
Elevation of Privilege	Broken RBAC; insecure admin endpoints; RBAC bypass	RBAC/ABAC; tenant isolation; authorization middleware; security testing; IAST

Security Testing & Monitoring Requirements

- Automated SAST/DAST in CI; dependency scanning (SCA).
- Pen-test prior to production launch; yearly thereafter.
- Centralized logging (SIEM-ready) with alerting for auth anomalies, webhook failures, privilege changes.
- Regular key rotation; secrets stored in a managed vault; break-glass accounts controlled.